UNITÀ 1 · CYBERSECURITY · LEZIONE 6

Cyberchallenge: Capture the Flag

Gare in cui si attacca e si difende per davvero, ma solo dove è permesso.
Il modo più divertente, e legale, di diventare bravi in sicurezza.

5G TPSI Formati, categorie, CyberChallenge.IT, allenamento etico

PER COMINCIARE

Hai mai partecipato a una gara di informatica?

SONDAGGIO

- **A** Mai
- **B** Olimpiadi di informatica o gare simili
- **C** Una gara di sicurezza o una CTF
- **D** Un hackathon

IL GIOCO

Trova la bandiera, consegnala, prendi i punti

Una **flag** è una stringa segreta nascosta nella sfida, come `picoCTF{...}`: se la trovi, hai risolto.

Jeopardy

Una griglia di sfide indipendenti, per categoria e punteggio. Il formato più comune.

Attack-Defense

Ogni squadra ha gli stessi servizi vulnerabili: li corregge e attacca quelli degli altri.

King of the Hill

Si conquista un sistema e lo si tiene il più a lungo possibile.

LE CATEGORIE

Sei famiglie di sfide

Categoria	Che cosa si fa	Che cosa ti serve
Web	Trovare falle in applicazioni web	HTTP, JavaScript, SQL: la lezione 5
Crypto	Rompere cifrari deboli o usati male	Codifiche, hash, un po' di matematica
Forensics	Analizzare file, immagini, catture di rete	Formati dei file, Wireshark
Reverse	Capire che cosa fa un programma senza sorgente	Java, C, un po' di assembly
Pwn	Sfruttare errori di memoria in programmi binari	C, puntatori, stack
OSINT e **Misc**	Fonti aperte, logica, Linux, giochi di ingegno	Riga di comando e curiosità

CURIOSITÀ SÌ, MA CON REGOLE

Il confine tra gioco e reato

> **Il mio crimine è la curiosità.**
>
> **The Mentor** (Loyd Blankenship), dal "Manifesto dell'hacker", rivista *Phrack*, 1986

Sì

Piattaforme di gara, laboratori volutamente vulnerabili, macchine tue.

Sì, con permesso

Bug bounty e test con regole scritte che indicano il perimetro.

No

Il sito della scuola, il Wi-Fi del vicino, l'account di un amico "per scherzo".

QUIZ ETICO

Durante una CTF scopri una falla nel sito che ospita la gara, non in una sfida. Che cosa fai?

QUIZ

A La sfrutti: è una gara di hacking, vale tutto

B La usi solo per vedere le flag, senza toccare i punteggi

C La segnali agli organizzatori, senza sfruttarla

D La pubblichi sui social per avvisare tutti

IN ITALIA

CyberChallenge.IT e i percorsi per giovani

CyberChallenge.IT è un programma gratuito di addestramento in cybersecurity per ragazze e ragazzi tra i **16 e i 24 anni**, organizzato dal Laboratorio Nazionale di Cybersecurity del **CINI** con università e enti in tutta Italia.

- Si entra con un test di ammissione: logica, programmazione, problem solving.
- Seguono lezioni e laboratori in una sede vicina, per alcuni mesi.
- Si chiude con gare CTF, fino a una finale nazionale a squadre.

Altri percorsi

OliCyber.IT: le Olimpiadi Italiane di Cybersicurezza, per studenti delle superiori.

TeamItaly: la nazionale giovanile che partecipa alla European Cybersecurity Challenge di ENISA.

Requisiti, date e sedi cambiano ogni anno: controlla sui siti ufficiali.

PUZZLE

Il percorso tipico di chi partecipa: metti in ordine

1. Segui le lezioni e i laboratori nella tua sede
2. Gareggi nella CTF locale con i compagni della sede
3. Superi il test di ammissione
4. Ti iscrivi online entro la scadenza del bando
5. La squadra della sede partecipa alla finale nazionale
6. I migliori possono essere selezionati per allenarsi con TeamItaly

AL COMPUTER · 15 minuti

Prima flag: CyberChef

Questa stringa nasconde una flag sotto due strati di codifica:

```
NmU2Zjc2NjE3NTZjNjE3YjYyMzYzNDVmNmU2ZjZlNWY2MzY5NjY3MjYxN2Q=
```

1. Apri **gchq.github.io/CyberChef** e incolla la stringa.
2. Riconosci il primo strato dal finale `=` e applica l'operazione giusta.
3. Guarda il risultato: solo cifre e lettere da a a f. Applica il secondo passo.
4. Scrivi la flag e la ricetta in **flag1-cognome.txt**.

Controllo: la flag inizia con `novaula{` e finisce con `}`. Il suo testo ti dice che cosa NON è Base64.

QUIZ A TRABOCCHETTO

Quale di queste trasformazioni protegge davvero un segreto?

QUIZ

A Codifica Base64

B Conversione in esadecimale

C ROT13

D AES con una chiave segreta

AL COMPUTER · 25 minuti

OverTheWire Bandit: i primi livelli

1. Dal Prompt dei comandi: `ssh bandit0@bandit.labs.overthewire.org -p 2220`, password `bandit0`.
2. Esegui `ls` e `cat readme`: trovi la password del livello 1.
3. Esci con `exit` ed entra come `bandit1`. Il file si chiama `-`: come lo leggi?
4. Leggi su **overthewire.org/wargames/bandit** il testo di ogni livello e vai avanti finché puoi.
5. In **bandit-cognome.md** annota per ogni livello comando e idea, **non** le password.

Controllo: ogni password è una stringa di 32 caratteri. Per il file `-` funziona `cat ./-`.

COME SI AFFRONTA UNA SFIDA

Il metodo vale più del trucco

1. **Leggi** tutto il testo: titolo e descrizione sono indizi.
2. **Osserva**: tipo di file, codifiche, porte, sorgente della pagina.
3. **Fai un'ipotesi** e provala con lo strumento più semplice.
4. **Cerca** documentazione: man, RFC, manuali, write-up di gare passate.
5. **Scrivi** la tua write-up: che cosa hai provato e perché ha funzionato.



AL COMPUTER · 20 minuti

Sfida crypto: forza bruta su Cesare, in Java

```java
static String sposta(String testo, int k) {
  StringBuilder sb = new StringBuilder();
  for (char c : testo.toCharArray())
    sb.append(Character.isLowerCase(c)
        ? (char) ('a' + (c - 'a' + k) % 26) : c);
  return sb.toString();
}
// nel main
String cifrato = "yzglfwl{npdlcp_lgpgl_dzwz_25_nstlgt}";
for (int k = 1; k < 26; k++) {
  String prova = sposta(cifrato, k);
  if (prova.startsWith("novaula{"))
    System.out.println("chiave " + k + ": " + prova);
}
```

Salva in **Cesare.java** dentro una classe `Cesare` ed esegui `java Cesare.java`.

Controllo: il programma stampa una sola riga, con la chiave **15** e una flag che spiega perché Cesare è debole.

Bonus: senza sapere che la flag inizia con `novaula{`, come sceglieresti la riga giusta?

AL COMPUTER · 20 minuti

picoGym: la palestra di picoCTF

1. Vai su **play.picoctf.org** e accedi con l'account creato con l'indirizzo della scuola.
2. Apri **Practice**, filtra la categoria **General Skills** e ordina per numero di soluzioni.
3. Risolvi almeno due sfide, partendo da *Obedient Cat* se è disponibile.
4. Per ognuna scrivi in **pico-cognome.md**: nome, categoria, idea, comandi usati.

Controllo: le flag hanno il formato `picoCTF{...}` e la piattaforma segna la sfida come risolta quando la invii.

MINI CTF A SQUADRE

Apri il lucchetto con le flag di oggi



- 1ª e 2ª cifra: la chiave che decifra il messaggio di Cesare
- 3ª cifra: quanti formati di CTF abbiamo visto
- 4ª cifra: il livello di Bandit a cui si accede con la password del readme

codice

BIGLIETTO D'USCITA

Completa prima di uscire

Il formato CTF con una griglia di sfide indipendenti si chiama _____.

Base64 è una _____, non una cifratura.

Per leggere in Bandit un file chiamato - si scrive cat _____.

Il programma italiano di addestramento per giovani tra 16 e 24 anni si chiama _____.

Segnalare una falla al proprietario senza sfruttarla si chiama divulgazione _____.

⏱ 3:00

RIEPILOGO

Cosa portiamo a casa

- Jeopardy, Attack-Defense, King of the Hill
- Web, crypto, forensics, reverse, pwn, OSINT
- Solo bersagli autorizzati, segnalazioni responsabili
- CyberChallenge.IT, OliCyber.IT, TeamItaly
- Allenamento: CyberChef, Bandit, picoGym, Juice Shop
- Codifica non è cifratura

Hai una domanda su una slide? Usa il pulsante **? Domande** in basso: la vedrà il docente e tutta la classe.